

**Licenciatura en Sistemas de Información
Analista en Sistemas de Computación
Profesorado Universitario en Computación**

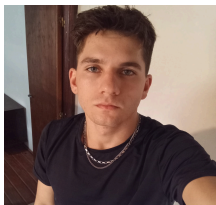


Actualidad Informática
Ingeniería de Software III

Profesores:

- Mgter. Sergio Daniel Caballero
- Mgter. Martín Rey
- Prof. ASC Alejandra Gonzales
- ASC Juan José Bolano

JL LK - TP 4 - IS3ACI

Foto	Apellido y Nombre	Correo electrónico
	Ledesma, Junior	juniorledesmaok@gmail.com
	Krauss, Leandro Ezequiel	kraussleandro598@gmail.com

Año 2026

SEI - Análisis y Gestión de Riesgos

El presente análisis de riesgo ha sido confeccionado para el proyecto del "Software de organización y gestión de eventos académicos". En particular, se ha optado por la evaluación de los riesgos inherentes a todo el proceso de desarrollo, abarcando desde el relevamiento de requerimientos hasta la implantación. El mismo ha sido confeccionado siguiendo los lineamientos de la metodología Software Risk Management (SRM) del Software Engineering Institute (SEI).

Inventario de activos a proteger

- **Servidor de desarrollo y producción:** Entorno donde se aloja la aplicación web y la base de datos PostgreSQL.
- **Código fuente del producto:** Repositorio en GitHub con las implementaciones y especificaciones SDD.
- **Equipo de desarrollo:** Los integrantes asignados al proyecto (Junior Omar Ledesma y Leandro Ezequiel Krauss).
- **Datos del sistema:** Información de usuarios (participantes, disertantes, organizadores), credenciales y registros de inscripción.
- **Especificaciones:** Documentos de requerimientos y definición de la arquitectura.

Objetivos

- Evaluar los riesgos relacionados al desarrollo del software de gestión de eventos académicos.
- Definir estrategias vinculadas a la gestión de los riesgos detectados, priorizando aquellos con mayor exposición.
- Definir planes de contingencia para las situaciones críticas cuyo impacto deba ser minimizado.

Equipo de trabajo

- Junior Omar Ledesma
- Leandro Ezequiel Krauss

Taxonomía de los riesgos

Identificador	Elemento	Riesgo	Vinculación del riesgo
R1	Servidor / Base de Datos	Caída o degradación del servicio por sobrecarga de peticiones simultáneas durante el cierre de inscripciones a eventos masivos.	Proyecto, Producto
R2	Equipo de desarrollo	Baja temporal o falta de disponibilidad de uno de los desarrolladores limitando la capacidad operativa del equipo.	Proyecto
R3	Autenticación y Datos	Exposición de endpoints públicos (login/registro) a ataques automatizados de fuerza bruta o inyección SQL.	Producto, Negocio
R4	Especificaciones	Fallos en la planificación por ambigüedad en los requerimientos para la generación dinámica de certificados (asistencia, autor, expositor).	Proyecto
R5	Integración / Comunicaciones	Bloqueo o fallo del proveedor de correo al intentar enviar notificaciones o confirmaciones masivas a los participantes.	Producto

Declaración de los riesgos

Riesgo	Detalle
R1 - Caída del servidor por sobrecarga	Condición: La plataforma permite la inscripción pública. En los días previos a la fecha límite, la concurrencia puede agotar los recursos de hardware del servidor. Consecuencia: Denegación de servicio temporal que impide la inscripción de participantes y la gestión por parte de los organizadores. Efecto: Quejas de los usuarios, pérdida de inscripciones y daño a la reputación de la plataforma.
R2 - Baja de un desarrollador	Condición: El equipo es reducido (2 personas). Consecuencia: Las tareas de desarrollo y pruebas asignadas al miembro ausente se detienen, sobrecargando al integrante restante. Efecto: Incumplimiento del cronograma de entregas.
R3 - Exposición de endpoints a ataques	Condición: Los formularios de inscripción y acceso (/api/v1/auth/login) están expuestos a internet sin suficientes restricciones perimetrales. Consecuencia: Posible robo de credenciales, accesos no autorizados o inyección de datos corruptos en la base de datos de usuarios. Efecto: Pérdida de integridad de los datos, vulneración de la privacidad de los participantes y repercusiones legales.
R4 - Ambigüedad en generación de certificados	Condición: Los certificados tienen distintas calidades (asistencia, aprobación, expositor). Si las reglas para su emisión no se elicitaban correctamente, el código generado no cumplirá la expectativa. Consecuencia: Se deberá refactorizar la lógica de negocio en etapas avanzadas del proyecto. Efecto: Desperdicio de horas de desarrollo y retraso en la entrega final.
R5 - Fallo en el envío masivo de correos	Condición: El sistema debe notificar confirmaciones. Un envío masivo puede provocar que el dominio sea catalogado como Spam o que el proveedor bloquee el puerto. Consecuencia: Los usuarios no reciben confirmación de su inscripción ni sus certificados digitales. Efecto: Sobrecarga de consultas manuales hacia los organizadores del evento.

Estimación de la probabilidad e impacto

Escalas según SEI: Probabilidad (Baja 1, Poco probable 2, Media 3, Altamente probable 4, Casi seguro 5). Impacto (Insignificante 1, Marginal 2, Medio 3, Crítico 4, Catastrófico 5).

Estimación de probabilidad para cada riesgo:

Identificador	Riesgo	Expresión	Probabilidad
R1	Caída del servidor por sobrecarga	Casi seguro	90%
R2	Baja de un desarrollador	Media	40%
R3	Exposición de endpoints a ataques	Altamente probable	68%
R4	Ambigüedad en generación de certificados	Poco probable	18%
R5	Fallo en el envío masivo de correos	Media	40%

Estimación del impacto para cada riesgo:

Identificador	Riesgo	Impacto
R1	Caída del servidor por sobrecarga	Crítico (4)
R2	Baja de un desarrollador	Medio (3)
R3	Exposición de endpoints a ataques	Catastrófico (5)
R4	Ambigüedad en generación de certificados	Marginal (2)
R5	Fallo en el envío masivo de correos	Medio (3)

Magnitud de exposición al riesgo

Cálculo de exposición: Impacto × Probabilidad.

Identificador	Riesgo	Impacto	Probabilidad	Exposición
R1	Caída del servidor por sobrecarga	4	90%	$4 * 0.90 = 3.6$ (Alto)
R3	Exposición de endpoints a ataques	5	68%	$5 * 0.68 = 3.4$ (Alto)
R2	Baja de un desarrollador	3	40%	$3 * 0.40 = 1.2$ (Medio)
R5	Fallo en el envío masivo de correos	3	40%	$3 * 0.40 = 1.2$ (Medio)
R4	Ambigüedad en generación de certificados	2	18%	$2 * 0.18 = 0.36$ (Bajo)

Se procede a desarrollar los planes de gestión para los dos riesgos con mayor exposición: R1 y R3.

Planes de gestión de los riesgos

Plan para R1 - Caída del servidor por sobrecarga

- **Importancia del riesgo:** Si este riesgo se dispara, la plataforma no estará disponible en el momento de mayor demanda, impidiendo el registro de participantes y afectando los objetivos del negocio.
- **Información requerida:** Monitoreo del uso de CPU, RAM, y límite de conexiones concurrentes en la base de datos PostgreSQL.
- **Responsable:** El equipo de desarrollo (Área infraestructura).
- **Recursos necesarios:** Herramientas de monitoreo y pruebas de estrés. Acceso a configuración del servidor.

Plan de acción (Preventivo):

1. Implementar índices adecuados en la base de datos para optimizar las consultas de validación de cupos (maxCapacity) y listado de eventos disponibles.
2. Ejecutar las pruebas de carga utilizando herramientas automatizadas para conocer el límite de operaciones por minuto que soporta el sistema antes de salir a producción.
3. Cachear las respuestas del listado público de eventos para reducir la carga directa sobre la base de datos.

Plan de contingencias (Reactivo):

1. **Disparador:** Las métricas del servidor indican un consumo de recursos superior al 90% o los usuarios comienzan a recibir códigos de error HTTP 503.
2. Levantar temporalmente una vista estática de “Sala de espera” que informe a los usuarios que su petición está en la cola para mitigar la sobrecarga de reintentos.
3. Escalar temporalmente los recursos del servidor (aumentar memoria/procesamiento) en el panel del proveedor de hosting.

Plan para R3 - Exposición de endpoints a ataques

- **Importancia del riesgo:** Un ataque exitoso implicaría la vulneración de los datos personales de los participantes y el acceso no autorizado a funciones de administración de eventos.
- **Información requerida:** Logs de autenticación fallida, registro de peticiones anómalas y monitoreo de tráfico.
- **Responsable:** Equipo de desarrollo (Backend).
- **Recursos necesarios:** Librerías de seguridad para validación de esquemas (Zod) y limitación de peticiones.

Plan de acción (Preventivo):

1. Incorporar controles de seguridad del framework OWASP en las especificaciones (specs) del proyecto.
2. Validar estrictamente todas las entradas de datos en el backend mediante esquemas definidos, rechazando cualquier carga útil que no coincida exactamente con los atributos esperados.
3. Implementar rate limiting en las rutas críticas (/api/v1/auth/login y /api/v1/auth/register).

Plan de contingencias (Reactivo):

1. **Disparador:** Detección de una anomalía en los logs (múltiples intentos de inicio de sesión fallidos o inyección de caracteres especiales en los formularios).
2. Bloquear automáticamente la dirección IP de origen en el firewall de la aplicación.
3. Invalidar todos los tokens JWT emitidos y requerir que los usuarios activos vuelvan a iniciar sesión por precaución.

Enriquecimiento de Spec (Integración de controles OWASP)

Para cumplir con la incorporación de controles derivados de OWASP, se ha seleccionado la Historia de Usuario HU-A2 correspondiente al módulo de autenticación de la plataforma (auth.spec.md).

A continuación se detalla la actualización de los criterios de aceptación enfocados en mitigar el riesgo de R3:

HU-A2: Inicio de sesión (Enriquecida)

Como usuario registrado, quiero iniciar sesión con mi email y contraseña, para acceder a mi cuenta y funcionalidades protegidas.

Criterios de aceptación funcionales:

- El sistema valida email y contraseña contra la base de datos.
- Si las credenciales son correctas, se devuelve access token + refresh token.
- Si las credenciales son incorrectas, se devuelve 401 con código AUTH_REQUIRED.

Criterios de aceptación de seguridad (Controles OWASP agregados contra R3):

- [OWASP API4:2023 - Unrestricted Resource Consumption]: Se debe implementar de manera estricta el middleware de Rate Limiting en el endpoint /api/v1/auth/login, permitiendo un máximo de 5 intentos por minuto por IP para prevenir ataques de fuerza bruta.
- [OWASP API2:2023 - Broken Authentication]: Tras superar el límite de 5 intentos fallidos consecutivos con un mismo email, la cuenta debe ingresar en estado de bloqueo temporal (Account Lockout) por 15 minutos.
- [OWASP API3:2023 - Broken Object Property Level Authorization]: La función validadora de credenciales no debe aceptar objetos de datos genéricos. Se deben validar y tipar estrictamente los atributos de entrada utilizando el esquema de Zod (loginSchema) antes de pr>
- [OWASP API8:2023 - Security Misconfiguration]: El mensaje de error en caso de credenciales inválidas debe ser genérico (ej. "Credenciales incorrectas") tanto para fallos de email como de contraseña, evitando la enumeración de usuarios válidos en la plataforma.